

CyberDefense Pro 2.0

2.1.5 Center for Internet Security (CIS) Benchmarks



Image courtesy of CIS Benchmarks™.

▼ Description

The image shows the official logo for CIS Benchmarks. On the left side, there is a solid blue circle with a white outline of a rectangle inside, which contains a white keyhole symbol, suggesting security or access control. To the right of the circle, the words "CIS Benchmarks" are written in bold blue letters, with a small trademark "TM" symbol at the top right of the word "Benchmarks." The image conveys a focus on security standards and best practices, which is the mission of CIS (Center for Internet Security) Benchmarks.

This lesson covers the Center for Internet Security (CIS) Benchmarks™.

The CIS Benchmarks™ are a robust set of best practices for the secure configuration of IT systems and applications. The CIS Benchmarks™ are developed as a collaboration between public and private sector security experts. They are designed to guide organizations on how to improve their security posture and help protect their IT systems and data from potential threats. The benchmark guidance includes recommendations on configuring hardware devices, operating systems, and applications to increase security, reduce vulnerabilities, and improve system performance. By following the CIS Benchmarks™, organizations can benefit from increased security and improved system performance while reducing risk.

The CIS Benchmarks™ were developed in 2003 by public and private sector security experts working with organizations to improve their information systems security. CIS established a consensus process to develop a set of security configuration guidelines based on best practices proven to increase the security of systems across industries. The benchmarks define best practice approaches to patching, hardening, and system logging and are the industry standard for secure configuration.

The Core CIS Benchmarks™

There are five core focus areas in the CIS Benchmarks™, including governance, people, process, technology, and organization. Within each core area are several subcategories and benchmarks that help organizations build effective cybersecurity programs. CIS provides different versions of the CIS Benchmarks™, allowing organizations to select ones aligned with their industry and organization type. The different CIS Benchmarks™ include the following:

- Enterprise benchmarks for large organizations with standardized architectures, including government organizations, financial services organizations, and energy and utility companies.
- SOHO/SMB benchmarks for smaller organizations, including residential and small business settings.
- Critical infrastructure benchmarks for the nation's critical infrastructure organizations, including utilities and transportation.
- Cyber Defense Intelligence benchmarks for organizations that need to protect sensitive data, such as government agencies and financial services firms.
- Healthcare benchmarks for organizations in the healthcare industry, including medical and dental practices and health insurance providers.
- Education benchmarks for K-12 and higher education organizations.
- Energy and utilities benchmarks for the energy and utility sectors, including power plants, transportation, and distribution.
- Telecommunications benchmarks for telecommunications providers, such as wired and wireless service providers.
- Retail benchmarks for the retail industry, including brick-and-mortar and online retailers.
- Government benchmarks for federal, state, and local government organizations.

The CIS Benchmarks™ are continually updated based on industry research and feedback from information security community members. They are freely available online (<https://www.cisecurity.org/cis-benchmarks/>) so that organizations can use them on-premises or as a cloud service. The CIS Benchmarks™ are a broad set of over 100 configuration guidelines covering different aspects of IT security. Additional modules contain specific security configuration guidelines for various technologies and operating systems, such as Microsoft Windows, UNIX, and Linux. The CIS Benchmarks™ can assess the security of individual systems and configurations, including large-scale, standardized implementations for distributed systems. Several vulnerability scanners, such as the licensed version of Tenable's Nessus scanner, include configuration scanning options to compare an endpoint's active configuration to the settings detailed in a CIS benchmark.

The CIS Benchmarks™ provide organizations with specific guidance on how to improve their security posture, help protect their IT systems and data from potential threats, and enable them to reduce their overall risk. The CIS Benchmarks™ allow organizations to reduce the risk of cyberattacks by following best practices for IT systems and application configuration. This includes following general

security practices and specific, detailed recommendations for configuration. By following the CIS Benchmarks™, organizations can benefit from increased security and improved system performance while reducing risk. The CIS Benchmarks™ can be used to assess the protection of individual systems and configurations and can be scaled up to evaluate the security of multiple systems and architectures.

The CIS Benchmarks™ are designed to be flexible and scalable to meet the needs of different organizations. CIS provides benchmarks in various formats, including as an online service and a downloadable, offline database. The CIS Benchmarks™ can assess the security of individual systems and configurations and large-scale, standardized implementations for multiple systems. The CIS Benchmarks™ are designed to promote standardized practices across industries and organizations. To benefit from the CIS Benchmarks™, organizations should select a set of benchmarks based on their industry and system architecture. They should then review the recommended security configuration settings and determine if they need to change their IT systems and applications to meet the benchmarks.

Organizations can benefit the most from the CIS Benchmarks™ when they approach them holistically. The benchmarks can help organizations identify specific areas for improvement in their cybersecurity program and enable them to prioritize necessary changes to harden their systems. Organizations can use a variety of tools to implement the CIS Benchmarks™. They can do so by purchasing an on-premises solution or using a cloud-based service, such as the CIS Benchmarks™ implementation tool. The implementation tool is a subscription-based service that allows organizations to select and configure a set of CIS Benchmarks™ based on their industry and organization type. It also provides access to a repository of detailed configuration settings for specific technologies and systems, such as Microsoft Windows, UNIX, and Linux. The implementation tool also includes configuration guidelines for implementing the CIS Benchmarks™ in different environments, such as on-premises or in the cloud.

The CIS Benchmarks™ are "living documents," meaning they are continuously changed and updated by the CIS community based on feedback and new research. CIS members can recommend changes or additions to the CIS Benchmarks™, which are reviewed and updated regularly. Organizations should first identify the specific benchmarks that are most relevant to them and then incorporate them into their cybersecurity program. Once organizations have selected the specific CIS Benchmarks™ they want to follow, they should determine the best way to implement them. This may include making technical changes such as installing new software, upgrading existing software, or changing configuration settings per the guidance outlined in a specific benchmark.